
ACCESS CONTROL POLICY

Document ID: POL-SEC-001 Version: v2.1 Effective Date: January 15, 2024 Review Date: January 15, 2025 Policy Owner: Information Security Team Approval Authority: Chief Information Officer
Classification: Internal Use Only

1. PURPOSE

This policy establishes the requirements and controls governing logical access to Acme Corporation's information systems, applications, and data. The intent of this policy is to ensure that access to information assets is granted only to authorized individuals based on legitimate business need, and that access controls are designed to prevent, detect, and deter unauthorized access.

2. SCOPE

This policy applies to all employees, contractors, consultants, temporary workers, and third-party service providers who access Acme Corporation systems. It covers all information systems owned or operated by Acme Corporation, including on-premises infrastructure, cloud-hosted environments, and software-as-a-service (SaaS) applications.

3. POLICY STATEMENTS

3.1 Logical Access Controls (CC6.1)

Acme Corporation implements logical access security controls across all systems and infrastructure to protect the confidentiality, integrity, and availability of information assets. These controls include:

- (a) Identification and Authentication: All users must be uniquely identified prior to accessing any Acme Corporation system. Shared or generic accounts are prohibited except where technically necessary, and such exceptions require documented approval from the Information Security Team and department head.
- (b) Access Restriction: User access privileges are restricted to the minimum necessary to perform assigned job functions (principle of least privilege). Access to sensitive systems, administrative interfaces, and production environments is granted based on documented business justification and manager authorization.
- (c) Segregation of Access: Access privileges are structured to enforce separation of duties. No single individual shall have access rights that allow them to both initiate and approve a transaction, or to access both production systems and source code repositories without documented compensating controls.
- (d) Prevention and Detection of Unauthorized Access: Access control lists, network segmentation, and host-based access controls are deployed across all system tiers. Authentication failures, privilege escalations, and anomalous access patterns are logged and monitored by the Security Operations function.

- (e) Physical and Remote Access: Remote access to internal systems is permitted only via the corporate VPN using approved configurations. Direct remote desktop or SSH access to production servers requires individual accountability and is restricted to members of the Infrastructure and Security teams.

3.2 Multi-Factor Authentication (CC6.6)

Acme Corporation requires multi-factor authentication (MFA) to protect against unauthorized access from sources external to its network boundaries.

- (a) MFA Requirement: Multi-factor authentication is mandatory for: - All remote access to corporate systems via VPN - Access to cloud management consoles (AWS, Azure, GCP) - Access to privileged or administrative accounts - Access to systems containing personally identifiable information (PII) or payment card data - All SaaS applications processing sensitive business data
- (b) Approved MFA Methods: Acceptable second factors include hardware security keys (FIDO2/WebAuthn), authenticator applications (TOTP-based), and push notifications through approved enterprise authentication platforms. SMS-based one-time passwords are deprecated and must not be used for high-risk system access. Exceptions require written approval from the CISO.
- (c) Boundary Protection: In addition to MFA, Acme Corporation deploys perimeter security controls including next-generation firewalls, intrusion detection systems (IDS), and web application firewalls (WAF) to protect against threats originating outside the entity's system boundaries. All external-facing endpoints are subject to continuous vulnerability scanning.
- (d) Credential Protection: Authentication credentials must not be shared, embedded in code or configuration files, or transmitted in cleartext. Secrets management solutions are used to store and rotate service account credentials.

3.3 User Provisioning and Access Management (CC6.2)

Access provisioning follows a defined workflow to ensure appropriate authorization before credentials are issued. When a new employee or contractor requires system access, the hiring manager submits an access request through the IT service desk.

Access is provisioned following approval; however, the formal registration process and explicit authorization steps are managed at the departmental level and may vary by business unit.

Role-based access control (RBAC) templates have been defined for common job functions to facilitate consistent provisioning. Access reviews are conducted periodically to validate continued business need.

3.4 Access Termination

Upon separation or role change, the People Operations team notifies IT of required access modifications. Account deprovisioning for terminated employees is completed within one (1) business day of the effective termination date. Contractor and third-party access is revoked upon contract expiration or earlier termination.

3.5 Access Reviews

Access rights for all users are reviewed on a semi-annual basis. System owners are responsible for certifying the continued appropriateness of user access within their systems. Certification results are documented and exceptions are remediated within 30 days.

3.6 Access Changes and Change Procedures (CC8.1)

Significant changes to access control configurations — including modifications to role definitions, privileged account permissions, or firewall rules — are subject to the change management process. Such changes require documented rationale and appropriate approvals prior to implementation in production environments.

4. RESPONSIBILITIES

- Information Security Team: Maintains this policy, operates access control tooling, reviews access logs, and manages exception processes.
- IT Operations: Implements provisioning and deprovisioning requests; maintains identity management infrastructure.
- Managers and System Owners: Authorize access requests; certify access during periodic reviews.
- All Personnel: Protect their credentials, report suspected unauthorized access, and comply with all requirements of this policy.

5. EXCEPTIONS

Requests for exception to this policy must be submitted in writing to the Information Security Team and include a description of the business need, proposed compensating controls, and a defined expiration date. Approved exceptions are logged and reviewed quarterly.

6. ENFORCEMENT

Violations of this policy may result in disciplinary action up to and including termination of employment or contract. Legal proceedings may be initiated where applicable law has been violated.

7. RELATED DOCUMENTS

- Password and Authentication Standards (STD-SEC-003)
- Privileged Access Management Procedure (PROC-SEC-007)
- Remote Access Standard (STD-SEC-009)
- Acceptable Use Policy (POL-SEC-004)
- Information Classification Policy (POL-SEC-002)

REVISION HISTORY

Version	Date	Author	Description
---------	------	--------	-------------

v1.0 2021-03-01 Information Security Initial release
v2.0 2023-01-10 Information Security Added MFA requirements; expanded
RBAC guidance
v2.1 2024-01-15 Information Security Updated cloud console MFA scope;
revised access review cadence
